Il convient toutefois de noter que, indépendamment de la nécessité ou non de consulter l'autorité de contrôle en fonction du niveau du risque résiduel, les obligations de conserver un rapport de l'AIPD et de mettre celle-ci à jour en temps utile demeurent.

IV. Conclusions et recommandations

Les AIPD sont un outil utile pour les responsables du traitement aux fins de l'établissement de systèmes de traitement de données répondant aux exigences du RGPD et peuvent être obligatoires pour certains types d'opérations de traitement. Leur mise en œuvre est adaptable et elles peuvent prendre différentes formes, même si le RGPD fixe les conditions de base à remplir pour une AIPD effective. La réalisation d'une AIPD devrait être considérée par les responsables du traitement comme une activité utile et positive aidant à se conformer à la législation.

L'article 24, paragraphe 1, définit comme suit la responsabilité fondamentale du responsable du traitement aux fins du respect du RGPD: «*Compte tenu de la nature, de la portée, du contexte et des finalités du traitement ainsi que des risques, dont le degré de probabilité et de gravité varie, pour les droits et libertés des personnes physiques, le responsable du traitement met en œuvre des mesures techniques et organisationnelles appropriées pour s'assurer et être en mesure de démontrer que le traitement est effectué conformément au présent règlement. Ces mesures sont réexaminées et actualisées si nécessaire*».

L'AIPD est un élément essentiel de la mise en conformité avec le règlement lorsqu'un traitement de données à risque élevé est prévu ou déjà effectué. Il convient par conséquent que les responsables du traitement utilisent les critères définis dans le présent document pour déterminer si une AIPD est ou non nécessaire. Dans sa politique interne, le responsable du traitement peut étendre cette liste au-delà des obligations légales fixées par le RGPD, ce qui pourra lui attirer une confiance accrue de la part des personnes concernées et des autres responsables du traitement.

Lorsqu'un traitement à risque potentiellement élevé est prévu, le responsable du traitement doit:

- choisir une méthodologie d'AIPD (voir les exemples donnés à l'annexe 1) qui satisfait aux critères de l'annexe 2, ou spécifier et mettre en œuvre un processus d'AIPD systématique:
  - conforme aux critères de l'annexe 2;
  - intégré aux processus existants de conception, de développement, de modification, de gestion des risques et d'examen opérationnel, selon les processus, le contexte et la culture internes;
  - impliquant les parties intéressées et définissant clairement leurs responsabilités (responsable du traitement, DPD, personnes concernées ou leurs représentants, unités opérationnelles, services techniques, sous-traitants, responsable de la sécurité des systèmes d'information, etc.);
- communiquer son rapport d'AIPD à l'autorité de contrôle compétente si la demande lui en est faite;
- consulter l'autorité de contrôle s'il n'a pas réussi à identifier des mesures suffisantes pour atténuer les risques élevés;
- procéder à un réexamen périodique de l'AIPD et du traitement qu'elle évalue, au moins lorsqu'un changement intervient dans les risques présentés par le traitement;
- documenter les décisions prises.